Propuesta de solución

PS - Scienza - Análisis EWA - Modificación de parámetros y ajustes de seguridad

Versión 01

Autor: Global Support – Lucas Barrera

Fecha de solicitud: *10/04/2019*

Mantis:

Fecha de creación: *10/04/2019*

Prioridad: *Media*

Módulo: *Basis*

1. Requerimiento / Situación actual / Problema reportado

Modificación de parámetros de seguridad. Ajustes de seguridad HANA y ABAP

Contenido

1. Requerimiento / Situación actual / Problema reportado 2
2. Premisas e impacto 3
2.1. Permisos de usuarios HANA 3
2.2. Auditoria de base de datos 3
2.3. Contraseñas por defecto 4
2.4. Usuario SAP* 4
2.5. Políticas de claves ABAP 5
2.6. Usuarios con permisos críticos 5
2.7. Auditoría de sistema SAP 8
3. Propuesta de solución 9
4. Estimación 9

2. Premisas e impacto

2.1. Permisos de usuarios HANA

Evidencia EWA:



Number of Additional Users with DATA ADMIN Privilege	1

DATA ADMIN provides the authorization to modify and delete every object in every schema.

Recommendation: Remove the DATA ADMIN privilege from all user accounts except the SYSTEM und _SYS_REPO users.

Observación:

Se encontró un usuario con permisos DATA ADMIN a nivel de base de datos HANA. Dicho permiso permite la eliminación de cualquier elemento de la base de datos. Se recomienda quitar dicho permiso

2.2. Auditoria de base de datos

Evidencia EWA:



10.1.2.1 Auditing Status

Auditing is disabled in the security settings of your SAP HANA database.

Recommendation: Activate the SAP HANA audit trail and define appropriate audit policies.

10.1.2.2 Audit Policies

No customer-defined audit policies are enabled.

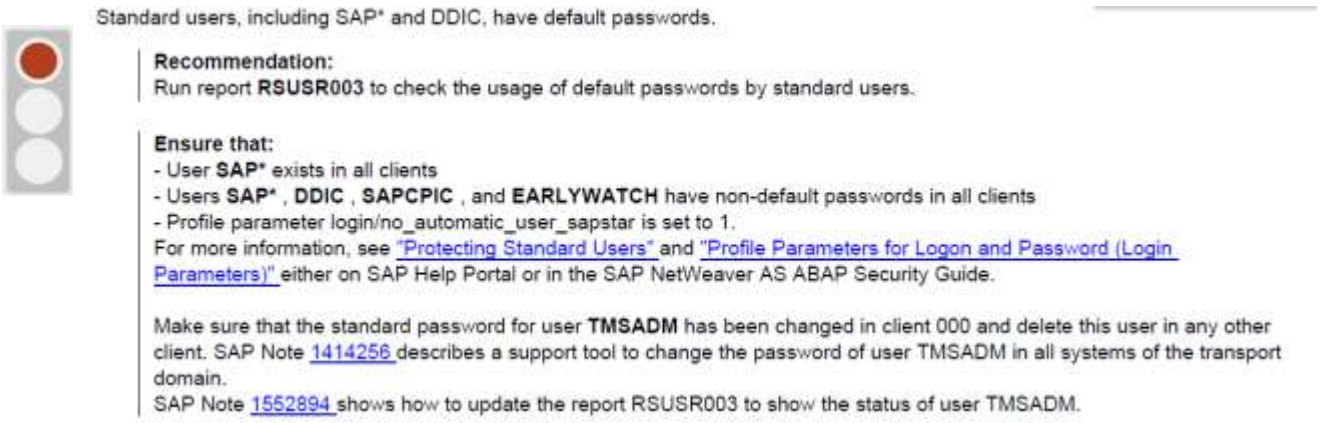
Recommendation: Define audit policies according to your needs.

Observación:

Se verifican que la auditoria de base de datos esta inactiva. Se recomienda la activación y configuración de dicha auditoría. Esto permitiría poder llevar un control de los cambios realizados sobre la base de datos.

2.3. Contraseñas por defecto

Evidencia EWA:



Standard users, including SAP* and DDIC, have default passwords.

Recommendation:
Run report **RSUSR003** to check the usage of default passwords by standard users.

Ensure that:
- User **SAP*** exists in all clients
- Users **SAP*** , **DDIC** , **SAPCPIC** , and **EARLYWATCH** have non-default passwords in all clients
- Profile parameter login/no_automatic_user_sapstar is set to 1.

For more information, see "Protecting Standard Users" and "Profile Parameters for Logon and Password (Login Parameters)" either on SAP Help Portal or in the SAP NetWeaver AS ABAP Security Guide.

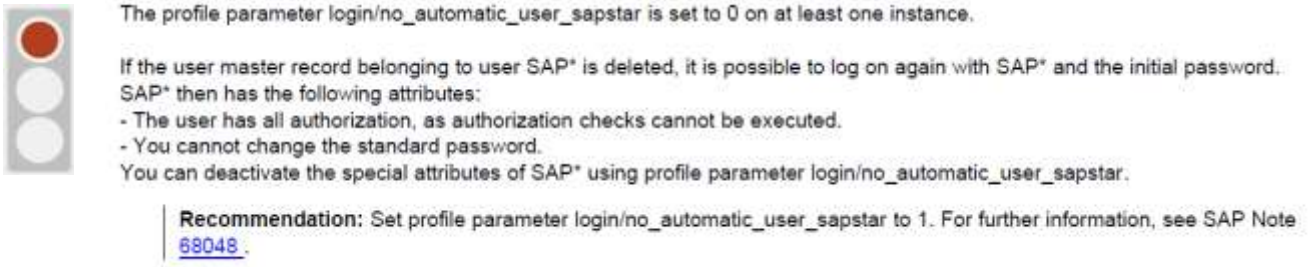
Make sure that the standard password for user **TMSADM** has been changed in client 000 and delete this user in any other client. SAP Note 1414256 describes a support tool to change the password of user TMSADM in all systems of the transport domain.
SAP Note 1552894 shows how to update the report RSUSR003 to show the status of user TMSADM.

Observación:

Se encontraron usuarios estándar con claves por defecto. Dichos usuarios tienen contraseñas conocidas y suponen un riesgo a la seguridad si no se modifican.

2.4. Usuario SAP*

Evidencia EWA:



The profile parameter login/no_automatic_user_sapstar is set to 0 on at least one instance.

If the user master record belonging to user SAP* is deleted, it is possible to log on again with SAP* and the initial password. SAP* then has the following attributes:
- The user has all authorization, as authorization checks cannot be executed.
- You cannot change the standard password.

You can deactivate the special attributes of SAP* using profile parameter login/no_automatic_user_sapstar.

Recommendation: Set profile parameter login/no_automatic_user_sapstar to 1. For further information, see SAP Note 68048 .

Observación:

El usuario SAP* tiene la capacidad de volver a crearse automáticamente con el reinicio de la instancia SAP si no se configura el parámetro que evita esta acción. Este usuario de sistema cuenta con permisos SAP_ALL y presenta un riesgo a la seguridad del Sistema si no se inhabilita.

Es aconsejable configurar el parámetro login/no_automatic_user_sapstar para evitar este inconveniente de seguridad.

2.5. Políticas de claves ABAP

Evidencia EWA:



Rating	Parameter	Instance	Current Value(s)
!	login/password_max_idle_initial	mdf-s30p_SPE_00	0

Initial passwords are valid for more than 14 days.

Observación:

Las mejores prácticas establecen que las contraseñas iniciales deben tener un tiempo de vigencia menor a 14 días. Para evitar ingresos indeseados con estas contraseñas iniciales, que generalmente suelen ser siempre las mismas.

Se recomienda ajustar el parámetro.

2.6. Usuarios con permisos críticos

- **Usuarios SAP_ALL.**
- **Usuarios con Permisos Modificación Tablas.**
- **Usuarios con Permisos Debug.**
- **Usuarios con Permisos para Visualizar Permisos Otro Usuario.**
- **Usuarios con Permisos para Modificar Contraseñas.**

Evidencia EWA:



Users with authorization profile SAP_ALL have full access to the system. There should be a minimum of such users. The number of users with this authorization profile is stated for each client.

Client	No. of Users Having This Authorization	No. of Valid Users	Rating
000	4	7	!
001	2	3	!
300	34	531	!

Authorization profile:
SAP_ALL

Observación:

La asignación de perfil SAP_ALL en el Sistema Productivo, no permite tener una visualización clara respecto a la confiabilidad del sistema, perdiendo la trazabilidad de los accesos sensibles.

La criticidad puede ser a nivel técnico permitiendo (apertura de mandante, modificación de tablas, asignar permisos amplios a otros usuarios) o de negocio (crear una order de pedido y contabilizar)
Se recomienda poder asígnales roles acordes a sus puestos de trabajo o evaluar la creación de roles específicos.
NOTA: Dicha tarea requiere un **análisis previo (el cual se estipula en la PS),** para verificar el sistema y hacer una propuesta acorde. Necesitaremos **junto al cliente** definir las actividades y, con ello, brindar alternativas que no tengan impactos negativos en las tareas diarias de los usuarios de SAP_ALL.
QUEDA FUERA DE ALCANCE el desarrollo de la resolución, solo se evaluará el análisis del sistema, dado que no tenemos evidencia de la complejidad y tiempos de demanda.

Evidencia EWA:

Unauthorized access to sensitive data is possible if too many users have this authorization. The specified number of users for each client have the checked authorization.

Client	No. of Users Having This Authorization	No. of Valid Users	Rating
001	2	3	✔
300	155	531	!

Authorization objects:
Object 1: S_TCODE with TCD=SE16, TCD=SE16N, TCD=SE17, TCD=SM30, or TCD=SM31
Object 2: S_TABU_DIS with ACTVT = 03 or 02 and DICBERCLS = *

Observación:

En base a la sumatoria de autorizaciones, ligada a la asignación de roles, varios usuarios pueden visualizar o modificar tablas críticas con datos sensibles en productivo.
Se recomienda poder restringir estos permisos.
NOTA: Dicha tarea requiere un **análisis previo (el cual se estipula),** para verificar cantidad de roles involucrados, asignaciones a usuarios y análisis de impacto. Con dicha información se podrá estimar una propuesta acorde.
QUEDA FUERA DE ALCANCE el desarrollo de la resolución, solo se evaluará el análisis del sistema, dado que no tenemos evidencia de la complejidad y tiempos de demanda.

Evidencia EWA:

Client	No. of Users Having This Authorization	No. of Valid Users	Rating
001	2	3	✔
300	91	531	!

Authorization objects:
Object 1: S_DEVELOP with ACTVT=02 (change) and OBJTYPE=DEBUG
Note: If you do not want to disable development in your system, you have to exclude the OBJTYPE=DEBUG with ACTVT=02 from the profile and allow any other object type for S_DEVELOP. This means that development and debugging with visualization is still possible.
You can achieve this by linking two authorizations to the object S_DEVELOP: one with all object types (except for "DEBUG") and all activities, and another for the object type DEBUG only and all activities (except for 02).

Observación:

Los usuarios con dichos permisos pueden eludir cualquier tipo de restricción de acceso, ingresando al código fuente de un programa y modificando los chequeos de autorización que restringen el acceso.
NOTA: Dicha tarea requiere un **análisis previo (el cual se estipula),** para verificar cantidad de roles involucrados, asignaciones a usuarios y análisis de impacto. Con dicha información se podrá estimar una propuesta acorde.
QUEDA FUERA DE ALCANCE el desarrollo de la resolución, solo se evaluará el análisis del sistema, dado que no tenemos evidencia de la complejidad y tiempos de demanda.

Evidencia EWA:

Client	No. of Users Having This Authorization	No. of Valid Users	Rating
001	2	3	✔
300	387	531	!

Authorization objects:
Object 1: S_TCODE with TCD = SP01 or SP01O
Object 2: S_ADMI_FCD with S_ADMI_FCD = SP01 or SP0R
Object 3: S_SPO_ACT with SPOACTION = BASE and DISP and SPOAUTH = * or __USER__

Observación:

Existen usuarios que están habilitados para visualizar el spool de cualquier usuario. Posible acceso a información no autorizada (Ej. Visualizar una factura del spool de otro usuario).
NOTA: Dicha tarea requiere un **análisis previo (el cual se estipula),** para verificar cantidad de roles involucrados, asignaciones a usuarios y análisis de impacto. Con dicha información se podrá estimar una propuesta acorde.
QUEDA FUERA DE ALCANCE el desarrollo de la resolución, solo se evaluará el análisis del sistema, dado que no tenemos evidencia de la complejidad y tiempos de demanda.

Evidencia EWA:

Client	No. of Users Having This Authorization	No. of Valid Users	Rating
001	2	3	✔
066	1	2	✔
300	61	531	!

Authorization objects:
Object 1: S_TCODE with TCD=SU01 or TCD=OIBB or TCD=OOUS or TCD=OPF0 or TCD=OPJ0 or TCD=OVZ5
Object 2: S_USER_GRP with ACTVT=05

Observación:

Los siguientes usuarios pueden cambiar y restablecer las contraseñas de todos los usuarios. Esto es muy arriesgado porque cualquiera de estos usuarios podría cambiar la contraseña e iniciar sesión con cualquier usuario.

NOTA: Dicha tarea requiere un **análisis previo (el cual se estipula),** para verificar cantidad de roles involucrados, asignaciones a usuarios y análisis de impacto. Con dicha información se podrá estimar una propuesta acorde.
QUEDA FUERA DE ALCANCE el desarrollo de la resolución, solo se evaluará el análisis del sistema, dado que no tenemos evidencia de la complejidad y tiempos de demanda.

2.7. Auditoría de sistema SAP

Observación:

Se recomienda activar la auditoria de sistema SAP (transacción SM20) para poder tener la información sobre los accesos de seguridad que puedan requerirse en caso de ser necesaria alguna investigación.

3. Propuesta de solución

- Ajustar los parámetros indicados. Crear y/o ajustar los roles necesarios y asignarlos a los usuarios
- Activar las auditorias de base de datos

Actividad	Tiempo estimado de tarea	Downtime solicitado
Permisos de usuarios HANA	3	N/A
Auditoría de base de datos	2	N/A
Contraseñas por defecto	2	N/A
Usuario SAP*	1	1
Usuarios con permisos críticos (*)	6	N/A
Auditoria SAP	1	N/A

Las tareas relacionadas a permisos de usuarios HANA y contraseñas por defecto deberán realizarse en los 3 ambientes (desarrollo, calidad y producción).

(*)**QUEDA FUERA DE ALCANCE** el desarrollo de la resolución, solo se evaluará el análisis del sistema, dado que no tenemos evidencia de la complejidad y tiempos de demanda.

4. Estimación

Análisis y documentación de la PS (YA INSUMIDO)

Análisis funcional	0 Horas
Análisis técnico	2 Horas

Análisis / desarrollo /Ejecución (A INSUMIR)

Ejecución y documentación (Desarrollo / Calidad / Producción)	15 Horas
Total de horas	**17 Horas**